Saudi GRC Platform

Api Specification

Source: `api-specification.md`

13 — API Specification

The live OpenAPI 3 spec is published at `/v3/api-docs`; Swagger UI at `/swagger-ui.html` (dev profile only). This document summarises the contract and the conventions every endpoint follows.

Auth

Endpoint	Method	Purpose
/api/auth/login	POST	username + password → access token (body) + refresh cookie
/api/auth/refresh	POST	refresh-cookie → new access token
/api/auth/logout	POST	revoke session
/api/auth/me	GET	current user + organisation
/api/auth/switch-org	POST	switch active organisation (platform admin)

Risk & ERM

Endpoint	Method	Purpose
/api/risk/risks	CRUD	Risk register
/api/risk/assessments	CRUD	Risk assessments
/api/risk/appetite	CRUD	Appetite statements
/api/risk/kris	CRUD	KRI definitions
/api/risk/kri-breaches	GET, POST	KRI breach events
/api/risk/scenarios	CRUD + /approve /reject /archive	Scenario analysis
/api/risk/emerging	CRUD + /review /escalate /mature /dismiss	Emerging risk

BCM

Endpoint	Method	Purpose
/api/bcm/services	CRUD	Critical services
/api/bcm/bia	CRUD + /approve	BIA records
/api/bcm/plans	CRUD	BCPs
/api/bcm/dr-plans	CRUD + /approve /reject /activate /archive /record-test	DR plans
/api/bcm/exercises	CRUD	Exercises
/api/bcm/invocations	CRUD + /declare /standdown	Crisis invocations
/api/bcm/crisis-templates	CRUD	Crisis comms templates

SCM

Endpoint	Method	Purpose
/api/scm/vendors	CRUD	Vendor register
/api/scm/dependencies	CRUD	Dependency map
/api/scm/resilience/alternates	CRUD + /approve /archive	Alternate suppliers
/api/scm/resilience/exit-plans	CRUD + /approve /reject /activate /archive /record-test	Exit plans
/api/scm/resilience/tests	CRUD + /start /complete /approve /cancel	Resilience tests
/api/scm/fourth-party	CRUD + /validate /mitigate /retire	Fourth-party exposure
/api/scm/contract-clauses	CRUD + /approve /deprecate	Contract clause library

TPRM

Endpoint	Method	Purpose
/api/v1/tprm/vendors	CRUD	TPRM vendor master
/api/v1/tprm/assessments	CRUD	Generic vendor assessment
/api/v1/tprm/onboarding	GET, POST	Onboarding pipeline
/api/v1/tprm/reassessments	GET	Reassessment due dashboard
/api/tprm/cyber-assessments	CRUD + /posture /submit /approve /retire	Third-party cyber risk

Cyber

Endpoint	Method	Purpose
/api/v1/cyber/frameworks	GET	Cyber frameworks
/api/v1/cyber/controls	GET (paged)	Controls (paged)
/api/v1/cyber/controls/all	GET	All controls (for filtering UI)
/api/v1/cyber/sub-controls	GET	Sub-controls
/api/v1/cyber/assessments	CRUD	Control assessments
/api/v1/cyber/incidents	CRUD + /transition	Cyber incidents
/api/v1/cyber/vulnerabilities	CRUD	Vulnerabilities
/api/v1/cyber/exceptions	CRUD	Exceptions
/api/v1/cyber/assets	CRUD	Cyber assets
/api/v1/cyber/assets/all	GET	All assets
/api/v1/cyber/evidence	GET	Cyber evidence
/api/v1/cyber/action-plans	CRUD	Cyber action plans

Incident & RCA

Endpoint	Method	Purpose
/api/incident/incidents	CRUD	Generic incidents
/api/incident/timeline	CRUD	Timeline events
/api/incident/lessons	CRUD	Lessons learned
/api/incident/rca	CRUD + /submit /approve /reject /generate-capas	Root-cause analysis

Privacy / PDPL

Endpoint	Method	Purpose
/api/privacy/ropa	CRUD	ROPA
/api/privacy/ropa-workflows/{code}	GET	Per-ROPA workflow bundle
/api/privacy/ropa-workflows/{code}/counts	GET	Per-ROPA counts
/api/privacy/notices	CRUD + /publish /archive /supersede	Privacy notices
/api/privacy/consents	CRUD	Consent records
/api/privacy/dsr	CRUD + /assign /fulfil /reject	DSR cases
/api/privacy/dpias	CRUD + /submit /approve /reject	PIAs
/api/privacy/breaches	CRUD + /notify /close	Personal-data breaches
/api/privacy/cross-border-transfers	CRUD + /assess /approve /reject	Cross-border transfers
/api/privacy/disposal-certificates	CRUD + /start /complete /verify	Disposal certificates
/api/privacy/data-sharing	CRUD + /submit /activate /expire /terminate	Data sharing agreements
/api/privacy/processor-assessments	CRUD + /score /approve /reject	Processor due diligence
/api/privacy/cyber-bridge/log	GET	Cyber→PDPL bridge audit log
/api/privacy/cyber-bridge/trigger	POST	Manual bridge fire

Compliance

Endpoint	Method	Purpose
/api/compliance/frameworks	GET	Frameworks
/api/compliance/requirements	GET	Requirements
/api/compliance/controls	CRUD	Controls
/api/compliance/policies	CRUD	Policies
/api/compliance/regulatory-changes	CRUD	Regulatory feed
/api/compliance/attestation-campaigns	CRUD	Campaigns

Evidence

Endpoint	Method	Purpose
/api/v1/evidence/items	CRUD	Evidence items
/api/v1/evidence/versions	CRUD	Versions
/api/v1/evidence/links	CRUD	Links
/api/evidence/chain	GET	Chain summaries
/api/evidence/chain/{id}	GET	Per-item chain report
/api/evidence/chain/{id}/verify	POST	Verify chain

Signature

Endpoint	Method	Purpose
/api/signature/transactions	CRUD	Transactions
/api/signature/transactions/inbox	GET	My inbox
/api/signature/transactions/by-entity	GET	Per-entity
/api/signature/transactions/{id}/sign	POST	Sign
/api/signature/transactions/{id}/reject	POST	Reject

CAPA

Endpoint	Method	Purpose
/api/capa/tasks	CRUD + /transition	CAPA tasks

Admin / Workflow

Endpoint	Method	Purpose
/api/admin/organisations	CRUD	Tenants
/api/admin/users	CRUD	Users
/api/admin/roles	CRUD	Roles
/api/admin/committees	CRUD + /dissolve	Committees
/api/admin/committees/meetings	CRUD + /start /complete /approve-minutes /cancel	Meetings
/api/workflow/workflows	CRUD	Workflows
/api/workflow/versions	CRUD + /promote	Versions
/api/notification/channels	CRUD	Channels
/api/notification/outbox	GET	Outbox

Reporting / Dashboard

Endpoint	Method	Purpose
/api/v1/dashboard/stats	GET	Dashboard KPIs

Endpoint	Method	Purpose
/api/v1/dashboard/heatmap	GET	Risk heatmap data
/api/v1/reporting/board-pack-pdf	POST	Generate board pack PDF
/api/v1/reporting/board-pack-pptx	POST	Generate board pack PPTX
/api/v1/reporting/risk-register-pdf	POST	Export risk register
/api/v1/reporting/risk-register-xlsx	POST	Export risk register
/api/v1/reporting/nca-filing-pdf	POST	NCA self-assessment filing
/api/v1/reporting/regulatory-package	POST	Per-regulator zip
/api/v1/reporting/schedules	CRUD	Scheduled reports

WebSocket

- Endpoint: `/ws` (STOMP).
- Topic prefix: `/topic/`.
- Per-org filtered topics: `/topic/{orgId}/changed.{entity}`.
- Used by every list page for live refresh.